THE COSMOS CO-OP. BANK LTD.
(Multistate Scheduled Bank)

CYBER SECURITY

Malware-Based ATM Cyber Heist

A Case Study of the Cosmos Bank Attack

Faculty

Dr. Mangal Singh

Group No. 25

23070123069 | Otniel Jhirad
24070123501 | Atharv Shelar
24070123502 | Dhanraj Chavan
24070123510 | Kunal Ranjan

Cosmos Bank & The Attack

THE COSMOS CO-OP. BANK LTD.
(Multistate Scheduled Bank)

About Cosmos Bank

- Established in **1906**
- Headquartered in **Pune, Maharashtra**

What Happened?

- In **August 2018**, Cosmos Bank suffered a sophisticated, coordinated cyberattack.
- Attackers targeted the bank's **ATM payment infrastructure** and **SWIFT system**.
- Thousands of fraudulent ATM transactions were carried out using compromised/cloned cards.
- Additional funds were transferred through fraudulent SWIFT transactions.

What made it Unique?

1. **Two attack paths were combined (ATM cash-out + SWIFT transfer fraud)**
   The attack therefore wasn't a single isolated banking breach—it combined attacks on ATM payment infrastructure and international payment infrastructure.
2. **It bypassed normal authorization**
   The malicious ATM environment could generate fraudulent authorization responses, preventing the normal Core Banking System checks from being performed.

How Does a Normal ATM Transaction Work?

1 ATM

- Customer inserts card and enters PIN.
- ATM sends the withdrawal request to the bank's payment network.

2 ATM/POS Switch

- Acts as the communication and transaction-routing layer.
- Receives the ATM request and forwards it to the appropriate banking system.

3 Core Banking System (CBS)

- Verifies the transaction.
- Checks the customer's account and available balance.
- Returns an approval or decline response.

4 Authorization Response

- The authorization response travels back through the switch to the ATM.

5 Cash Dispensed

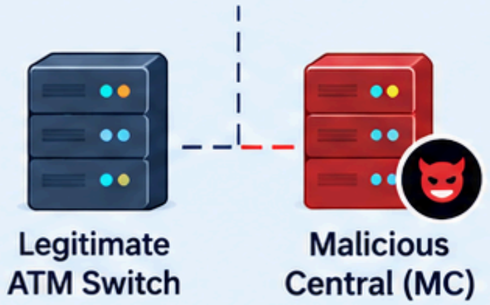
- If approved, the ATM dispenses the requested cash.
- The transaction is recorded by the banking system.

The ATM does not independently decide whether money should be dispensed — the transaction passes through the banking infrastructure for authorization.

How Did the Attackers Bypass the Normal ATM Process?

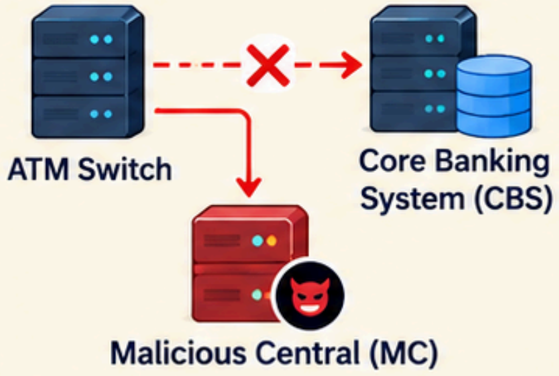
1 ATM Switch Compromised

- ATM payment-switch environment was compromised by malware.
- A **Malicious Central (MC)** was established alongside the legitimate switch.



2 Transaction Path Manipulated

- Normal **switch–CBS communication** was disrupted.
- Transaction requests could be handled by the malicious component.



3 Fake Authorization

- Malicious **ISO 8583 components** generated fraudulent authorization responses.
- The normal CBS authorization path was bypassed.

4 Cash Dispensed

- The ATM received a **false approval response.**
- Fraudulent withdrawals proceeded **without normal CBS validation.**

Compromise the switch → manipulate the transaction path → generate a false approval → cash withdrawal

How the ATM Switch Was Compromised

1 Initial Access & Perimeter Breach

- Reports suggest **spear-phishing and/or a compromised remote-administration / third-party interface** provided the initial foothold.
- Attackers established access inside the bank's **corporate network** and began reconnaissance.

2 Lateral Movement to ATM Switch

- After gaining initial access, attackers **moved laterally through the bank's internal systems** towards the ATM/payment infrastructure.
- They reached the ATM switch application server, running **IBM AIX** with **BPC SmartVista**.

3 Process / Library Injection

- A command-line utility was used to add a **malicious library** to the **running payment-switch process**.
- Execution within the trusted switch process could make the malicious activity harder for traditional **HIDS** mechanisms to detect.
- The injected library allowed the attackers to intercept and modify transaction messages.

4 Malicious ISO 8583 & Proxy Switch

- Malicious **ISO 8583 components** were introduced into the payment-switch environment.
- These components enabled a **Malicious Central (MC)** that acted as an **internal unencrypted loopback proxy**, intercepting transaction processing.
- This **isolated the legitimate switch from the CBS authorization path**, allowing fraudulent transaction responses without normal Core Banking System checks.

ATM Cash-Out: How the Money Was Physically Withdrawn

1 Recruitment of Money Mules

- Attackers reportedly used **darknet forums** to recruit people to participate in the ATM cash-out.
- Participants were offered payment for withdrawing cash using cloned cards.
- In some cases, people in India were lured with offers of work as **film extras**, but were actually used as money mules (later investification).

2 Cloned Debit Cards Provided

- Around **450 cloned, non-EMV debit cards** were prepared.
- Cards included **Cosmos Bank Visa and RuPay debit cards**.
- Card details and withdrawal instructions (when and where to withdraw) were provided to the money mules.

3 ATM Withdrawals

- Money mules used the cloned cards at ATMs to withdraw the fraudulently authorized funds.
- More than **12,000 international Visa transactions** and **2,849 domestic RuPay transactions** were carried out.
- Withdrawals were made across **28 countries**, including the US, UK, Russia, UAE, Canada and India.

4 Why 11 August 2018 (Saturday)?

- The cash-out was conducted on **Saturday, 11 August 2018**.
- FBI reporting indicates such operations are typically carried out on **weekends after banks close**, when monitoring and response times are reduced.
- Visa transactions occurred approximately **3:00 – 5:30 PM IST**, while RuPay transactions continued until about **10:00 PM IST**.

5 Scale of the Cash-Out

~12,000 international Visa transactions

2,849 domestic RuPay transactions

≈ ₹78 crore withdrawn internationally

Withdrawals carried out across **28 countries**

SWIFT Attack: How the Fraud Was Carried Out

1 Entry & Lateral Movement

- Attackers were **already inside the bank's network** following the earlier compromise.
- They moved laterally towards the system used for **international payment messaging** (SWIFT **environment**).

2 Compromising the SWIFT Environment

- Attackers reached the **bank's SWIFT SAA environment** used for international fund transfers.
- Using **malware and remote-access tools** (reportedly), they gained control over the bank's SWIFT interface.

3 Creating & Sending Fraudulent Messages

- Attackers created **fraudulent payment instructions** of **type MT103** (customer credit transfer) that looked genuine.
- These messages were sent through the **legitimate SWIFT network** to the receiving bank.

4 Result

On **13 August 2018**, three fraudulent MT103 messages were sent to a **Hong Kong account** (ALM Trading Limited at Hang Seng Bank).

A total of approximately **₹13.9 crore (≈ US$2 million)** was transferred in these transactions.

5 Why It Worked

- The messages originated from the **bank's own compromised SWIFT environment**, so they appeared to be from a legitimate participating institution.

- SWIFT **processed and delivered** the messages as submitted by an authorized sender.

- The fraud was not detected at the time, allowing the receiving bank to credit the funds to the attacker's account.

How Was the Attack Detected?

1 Abnormal Transaction Pattern

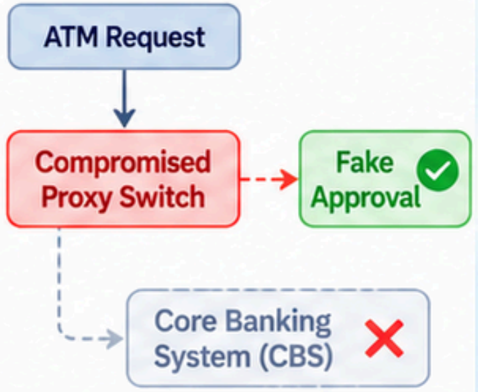
- **Repeated Visa and RuPay ATM withdrawals** occurred within a short period.
- Around **12,000 Visa transactions** were recorded across **28 countries**.
- The unusually high transaction volume and geographic spread indicated suspicious activity.
- The bank detected the repeated unusual transactions and, after observing the activity for **nearly two hours**, shut down its **Visa and RuPay payment systems**.

2 Card Network Alert

- **Visa and RuPay reportedly identified** unusual activity across their networks.
- They reportedly informed the **Reserve Bank of India (RBI)** about the fraudulent transactions.
- Public sources differ on which party raised the initial alarm first.

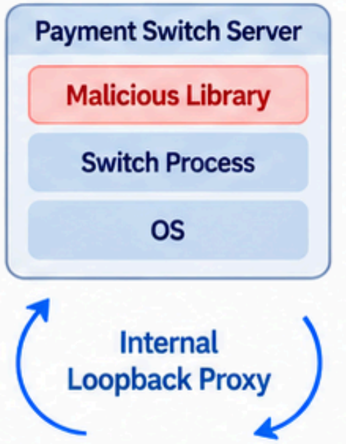
3 Authorization Bypass

- The proxy switch generated **fraudulent approval responses** for ATM transactions.
- The requests did not follow the normal **Core Banking System (CBS)** authorization path.
- This meant normal **balance checks and debit processing were bypassed**, allowing fraudulent withdrawals to proceed.



4 Why Host-Based Detection Could Fail

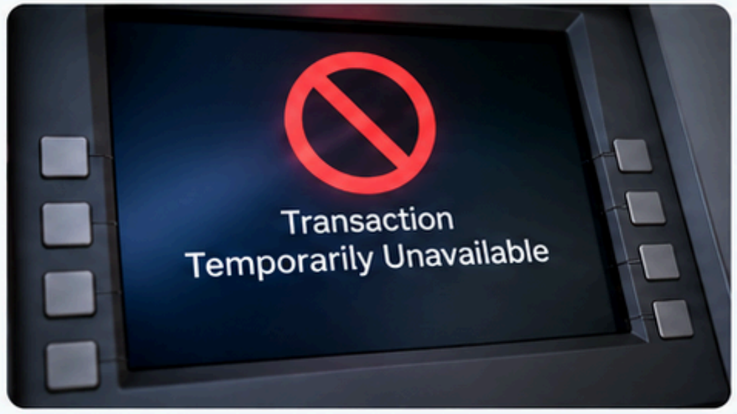
- The malicious library ran **inside the trusted payment-switch process.**
- This could make the activity harder for traditional **Host-Based Intrusion Detection Systems (HIDS)** to distinguish from legitimate switch activity.
- The internal loopback proxy handled transaction processing within the compromised environment, producing **no obvious suspicious external traffic.**



How Was the Attack Contained & Fixed?

1 Payment Systems Shut Down

- The bank shut down its **Visa and RuPay payment systems** after detecting abnormal transaction activity.
- This **stopped further fraudulent ATM withdrawals** and allowed the compromised infrastructure to be investigated.



2 SWIFT & ATM Infrastructure Secured

- The affected **SWIFT and ATM Switch servers** were secured and hardened after forensic investigation and CERT-In recommendations.
- Additional security measures were implemented before the payment services were restored.
- Cosmos Bank later moved its Visa and NPCI services to **Euronet's switching platform** in 2019.

3 How the New Controls Worked

- **Network segmentation** → separated critical systems and restricted lateral movement between networks.
- **SIEM + monitoring** → centralized security events and helped identify abnormal activity in real time.
- **HIPS / endpoint protection** → monitored critical hosts and helped prevent malicious processes from running.
- **ATM application whitelisting** → allowed only authorized applications to run on ATM systems, blocking unknown software.
- **Transaction monitoring** → established normal transaction patterns and flagged unusual transaction volume, timing and geographic activity.

Impact of the Attack

1 International ATM Cash-Out

~₹78 crore
Total amount withdrawn

~12,000
Visa transactions

28 countries
Across the world

2 Domestic ATM Cash-Out

~₹2.5 crore
Total amount withdrawn

2,849
RuPay transactions

Within India
Domestic ATMs

3 SWIFT Fraud

₹13.92 crore
Fraudulent SWIFT transfer

3
Suspicious SWIFT transactions

To an account at
Hang Seng Bank, Hong Kong

Total Loss

₹94.42 crore
(ATM cash-out + SWIFT transfer)

4 Customer & Operational Impact

- Legitimate customers were affected while Visa and RuPay payment systems were unavailable.
- Some customers reportedly saw **inflated account balances** and **withdrew excess funds**.
- Normal banking operations were disrupted while the compromised systems were secured.

5 Recovery

- **₹5.73 crore** was recovered from the frozen Hong Kong account in **February 2020**.
- Police had earlier reported recovery efforts for the SWIFT amount.
- **₹1.4 lakh** was recovered domestically from customers who withdrew excess funds.

Similar Attacks

City Union Bank – India (2017)

ATM / Cloned-Card Attack

1 Attack Vector

- Attackers hacked the bank's server and **stole debit-card information**.
- The stolen data was used to create **cloned debit/RuPay cards**.

2 Technical Execution

- Cloned cards were used at ATMs to make **fraudulent cash withdrawals**.
- About **₹33.93 crore** was withdrawn in two rounds in December 2017.

3 How It Was Identified?

- **Unauthorized ATM withdrawals** triggered the bank's complaint and subsequent investigation.
- ATM transaction records and **CCTV footage** helped investigators trace the operation.

4 Impact

- Approximately **₹33.93 crore** was siphoned from City Union Bank.
- The incident exposed weaknesses in **card-data and banking-server security**.

Bangladesh Bank – 2016

SWIFT fraud using malware

1 Attack Vector

- Exact initial entry method not conclusively established.
- Attackers gained access to the bank's **internal network** and **deployed malware**, with weak isolation around the SWIFT environment.

2 Technical Execution

- Malware targeted **SWIFT Alliance Access (SAA)** to **manipulate payment processing**.
- Oracle database records were altered and SWIFT confirmation messages/printouts were **suppressed**.

3 How It Was Identified / Stopped?

- Staff noticed **missing SWIFT transaction printouts** and manual printing also failed.
- A **spelling error** in one transfer request raised suspicion, which helped stop further transfers.
- The **Federal Reserve Bank of New York** also sent queries about several payment instructions.

4 Impact

- 35 fraudulent payment instructions attempted; 5 succeeded (about **US$101 million**).
- Approximately **US$81 million** was ultimately stolen (around US$20 million recovered).

Conclusion — What Did the Attack Teach Us?

What Did It Teach Us?

- **Trusted systems can become attack points** — securing customer accounts alone is not enough.
- **Payment infrastructure needs strong isolation** — so a compromised system cannot affect other critical systems.
- **Transaction-level monitoring is essential** — to detect unusual volume, timing and geographic patterns.
- **Endpoint and application controls** — can prevent unauthorized software from operating inside critical banking systems.
- **Early detection matters** — the longer attackers remain inside trusted infrastructure, the greater the potential financial and operational damage.

Could This Attack Happen Again?

Yes — potentially in a different form.

- Attackers could target ATM switches, SWIFT systems, APIs, payment middleware or privileged credentials.
- Stronger security controls reduce the risk, but no security system completely eliminates the possibility of a future compromise.
- The same techniques, or new methods, could be used to target similar trusted banking infrastructure again.

Final Takeaway

> **Protect the systems that authorize and move money — not just the accounts that hold it.**

References

[1] Securonix Threat Research, "Cosmos Bank SWIFT/ATM US$13.5 Million Cyber Attack Detection Using Security Analytics," Aug. 2018.
[2] The Register, "Hackers faked Cosmos backend to hoodwink bank out of $13,5m," 29 Aug. 2018.
[3] IANS via Moneylife, "NPCI blames Cosmos Bank for malware attacks," 16 Aug. 2018.
[4] BankInfoSecurity, "Seven Arrests in Cosmos Bank Heist.
[5] Indian Cooperative / RBI, "Basic Cyber Security Framework for UCBs.
[6] Seqrite, "RBI circular and 31 March 2019 deadline.
[7] IJIRL, "A Case Study on Cyber Security Threat to Cosmos Bank," 2023.

Thank You

Cosmos Bank ATM Switch Compromise — 2018

Understanding the breach, attack execution, detection, impact and lessons learned